BIL 481 Software Engineering - Project Assignment 1

Proje Adı: Yazılım Tedarik Zinciri Risk Tarayıcısı (yztr) / Software Supply Chain Risk Scanner

Grup Adı: CodeShield

1. Project Definition Document

Yazarlar (Authorship): Nuh Yusuf Sabırer, Kaan Zor

İçindekiler (Table of Contents)

- Proje Adı
- Proje Özeti
- Hedefler (Objectives)
- Kapsam (Scope)
- Hedef Kitle (Target Audience)
- Temel Özellikler (Key Features)
- Bütçe ve Kaynaklar (Budget and Resources)
- Riskler ve Azaltma Stratejileri (Risks and Mitigation Strategies)
- Proje Başarı Kriterleri (Project Success Criteria)
- Dokümana Özel Görev Matrisi (Document-Specific Task Matrix)

1.1 Proje Adı

Yazılım Tedarik Zinciri Risk Tarayıcısı / Software Supply Chain Risk Scanner (yztr)

1.2 Proje Özeti

Modern yazılım projeleri yüzlerce açık kaynaklı pakete bağımlıdır ve bu paketlerin çoğu dolaylı (transitive) bağımlılıklardır. Kod değişiklikleri "pull request" (PR) süreçlerinde incelense de kilit dosyalarındaki (lockfile) değişiklikler genellikle gözden kaçar; bu da bilinen zafiyetlerin, uyumsuz lisansların veya kötü niyetli benzer paketlerin (typosquatting/slopsquatting) projeye sızmasına yol açabilir. yztr projesi; npm, PyPI ve Maven bağımlılıklarını denetleyen, bir PR'ın temel dalı (base branch) ile yeni commit'i

arasındaki risk farkını izole eden ve GitHub Actions üzerinden tek bir PR yorumu ile bildirim yapan Java tabanlı bir komut satırı aracıdır.

1.3 Hedefler

- Açık kaynaklı ve kapalı kaynaklı (private) projelerin tedarik zinciri güvenliğini GitHub Advanced Security gibi ücretli araçlara ihtiyaç duymadan sağlamak.
- Güvenlik açığı, lisans uyumsuzluğu ve kötü niyetli paket denetimlerini tek bir ücretsiz Java aracında birleştirmek.
- PR ekranlarını gereksiz bildirimlerle doldurmak yerine eyleme dönüştürülebilir, güncellenen tek bir Markdown yorumu üretmek.

1.4 Kapsam

- **Dahil Olanlar:** npm (package-lock.json), PyPI (poetry.lock, uv.lock, requirements.txt) ve Maven (CycloneDX SBOM) bağımlılıklarının analizi. OSV.dev üzerinden zafiyet taraması, SPDX lisans uyumluluk denetimi ve npm ile PyPI için typosquatting/slopsquatting tespiti projeye dahildir. Çevrimdışı (offline) mod desteği.
- **Dahil Olmayanlar:** Dependabot gibi otomatik güncelleme PR'ları açma işlevi veya mevcut paket kodlarının indirilip çalıştırılması (sadece meta veri okunur) kapsam dışıdır. Maven paketleri için typosquatting kontrolü desteklenmemektedir.

1.5 Hedef Kitle

- Açık kaynak veya kapalı kaynak projelerde çalışan yazılım geliştiricileri.
- Tedarik zinciri saldırılarını önlemek isteyen Güvenlik Uzmanları (Security Leads) ve Kod İnceleyicileri (Code Reviewers).
- Kapalı kaynaklı ticari yazılımlara viral (örn. GPL-3.0) lisansların girmesini engellemek isteyen Depo Bakımcıları (Repository Maintainers).

1.6 Temel Özellikler

1. **Bağımlılık Girdisi İşleme:** Npm, PyPI ve Maven formatlarındaki kilit dosyalarını (lockfile) ayrıştırarak kesin paket listelerini çıkarma.

2. **Pull Request (PR) Fark Analizi:** "Base" ve "head" referansları arasındaki Git farkını okuyarak yalnızca yeni eklenen, güncellenen veya sürümü düşürülen paketlerin getirdiği riskleri hesaplama.
3. **Bilinen Zafiyet Denetimi:** OSV veri tabanını kullanarak (çevrimiçi veya çevrimdışı yerel ayna ile) CVE/GHSA eşleştirmesi yapma ve en düşük güvenli sürümü önerme.
4. **Lisans Çakışması Kontrolü:** SPDX ifadelerini normalize ederek projenin dağıtım modeline (örn. DISTRIBUTED_BINARY) ve özel lisans politikalarına göre uyumluluk değerlendirmesi yapma.
5. **Typosquatting ve Sahte Paket Tespiti:** Eklenen paket isimlerini Damerau-Levenshtein mesafesi ile analiz ederek en popüler 15.000 paketle karşılaştırma ve kayıt defterlerinde var olmayan (yapay zeka tarafından uydurulmuş) paketleri işaretleme.

1.7 Bütçe ve Kaynaklar

- **İnsan Kaynağı:** 5 kişilik (Nuh Yusuf Sabırer, Kaan Zor, Ömer Ali Sarıcalar, Yusuf Emir Coşar, Ramazan Emir Keleş) geliştirici ekibi. Toplamda yaklaşık 8 haftalık (12 Ekim - 11 Aralık 2026) proje süresi boyunca haftalık kişi başı ~15 saat efor ayrılacaktır.
- **Teknoloji ve Araçlar:** Java 21 LTS, Maven, H2 gömülü veri tabanı, GitHub Actions, JUnit 5, picocli (CLI). OSV.dev, PyPI ve npm açık kayıt defteri API'leri.
- **Bütçe:** Kullanılan tüm diller, araçlar, bağımlılıklar ve dış API'ler açık kaynaklı ve ücretsiz olduğundan, proje için ek bir finansal bütçe veya donanım maliyeti öngörülmemektedir.

1.8 Riskler ve Azaltma Stratejileri

- **Risk:** npm ve PyPI API'lerinde hız sınırına (rate limit) takılma.
    - **Azaltma Stratejisi:** Kayıt defteri sorguları sadece yeni eklenen paketler için yapılacak, yerel önbellek (cache) kullanılacak ve "retry" mekanizmaları eklenecektir.
- **Risk:** Typosquatting algoritmasının çok fazla yanlış pozitif (false-positive) sonuç üretmesi.
    - **Azaltma Stratejisi:** YAML politika dosyasında kullanıcılar için yapılandırılabilir bir typosquat_threshold ayarı sunulacak ve algoritma test verileriyle optimize edilecektir.

1.9 Proje Başarı Kriterleri

1. **Doğruluk Başarısı:** Değerlendirme derlemindeki ~20 açık kaynaklı proje üzerinde OSV-Scanner aracı ile en az %95 uyum (agreement) sağlanması.
2. **Algoritma Başarısı:** Typosquatting kontrolünde kesinliğin (precision) 0.80'in üzerinde olması ve en popüler 15.000 pakette yanlış pozitif oranının %1'i geçmemesi.
3. **Performans Başarısı:** Çevrimiçi modda 1000 paketlik bir kilit dosyasının soğuk önbellekle maksimum 90 saniyede, sıcak önbellekle maksimum 20 saniyede taranması.

1.10 Dokümana Özel Görev Matrisi (Project Definition Document)

Görev	Sorumlu	Neden (Rationale) Assignment-1.pdf
Doküman Taslağı & Kapsam Tanımı	Kaan Zor	Scrum Master rolü gereği projenin genel sınırlarını ve hedeflerini belirlemeye en hakim kişidir.
Özellikler & Başarı Kriterleri Çıkarımı	Nuh Yusuf Sabırer	Mimar (Architect) rolüyle sistemin teknik yeterliliklerini ve doğruluk hedeflerini (NFR) belirler.
Risk Analizi ve Kaynak Planlama	Kaan Zor	Zaman yönetimi ve proje süreç planlamasından sorumlu olduğu için.